

WEB APPLICATION VULNERABILITY ASSESSMENT

Security Assessment Using Nmap, OWASP ZAP & Browser DevTools

Prepared By : Tamizharasan S

Internship Future Interns – Cyber Security

Target Website <http://demo.testfire.net>

AUGUST 2026

Executive Summary

This report presents a security assessment of the web application demo.testfire.net, using Nmap, OWASP ZAP, and browser-based header and cookie inspection.

The assessment was conducted using passive and automated scanning techniques to understand the application's security posture without performing manual exploitation.

Findings include exposed network services, missing security headers, and weak cookie configuration — along with practical, business-friendly recommendations.

4

Open Ports Identified

15

Security Alert Categories

Medium

Overall Risk Rating

Assessment Overview



Purpose

To evaluate the security of the web application using passive, non-destructive assessment techniques.



Scope

- Passive assessment only
- No exploitation
- No brute-force attacks
- No denial-of-service testing



Approach

Assessment performed using Nmap, OWASP ZAP, and Chrome DevTools to identify configuration and exposure issues.

Tools Used

1

Nmap

Network and port scanning to identify exposed services

2

OWASP ZAP

Automated web application security assessment

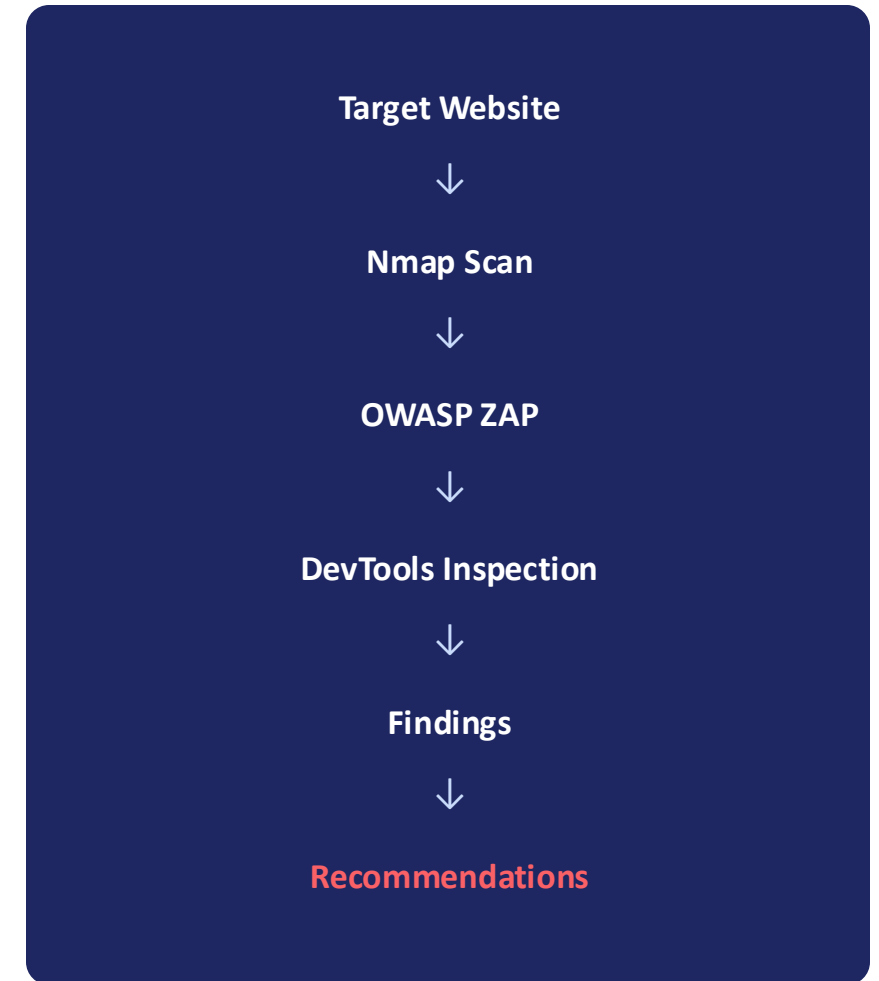
3

Chrome DevTools

HTTP response header and cookie inspection

Methodology

- 1 Selected a public test website (demo.testfire.net)
- 2 Performed network scanning using Nmap
- 3 Reviewed the website using OWASP ZAP
- 4 Inspected HTTP headers and cookies using Chrome DevTools
- 5 Documented findings and produced recommendations



Nmap Scan Results

Command Used: `nmap -Pn demo.testfire.net`

Observations

- Target host was reachable
- 4 open ports identified: 53 (DNS), 80 (HTTP), 443 (HTTPS), 8080 (HTTP-Proxy)
- 995 ports filtered by firewall
- Port 8080 alongside 80/443 increases exposed attack surface

Risk Level: Low–Medium

Recommendation: Close or restrict unnecessary open ports (e.g. 8080).

```
tamizharasan1607@penguin:~$ nmap -Pn testphp.vulnweb.com
Starting Nmap 7.93 ( https://nmap.org ) at 2026-08-09 16:29 IST
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.0036s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain

Nmap done: 1 IP address (1 host up) scanned in 8.40 seconds
tamizharasan1607@penguin:~$
```

Figure 1 — Nmap scan output for demo.testfire.net

OWASP ZAP Assessment

Tool: OWASP ZAP 2.17.0 **Target:** http://demo.testfire.net

An automated scan (spider + passive analysis) was completed successfully, identifying 15 categories of security alerts — including missing security headers, absence of anti-CSRF tokens, cookie misconfigurations, and server version disclosure.

Absence of Anti-CSRF Tokens	Medium
CSP Header Not Set	Medium
Missing Anti-Clickjacking Header	Medium
Cookie without SameSite Attribute	Low
Server Leaks Version Information	Low

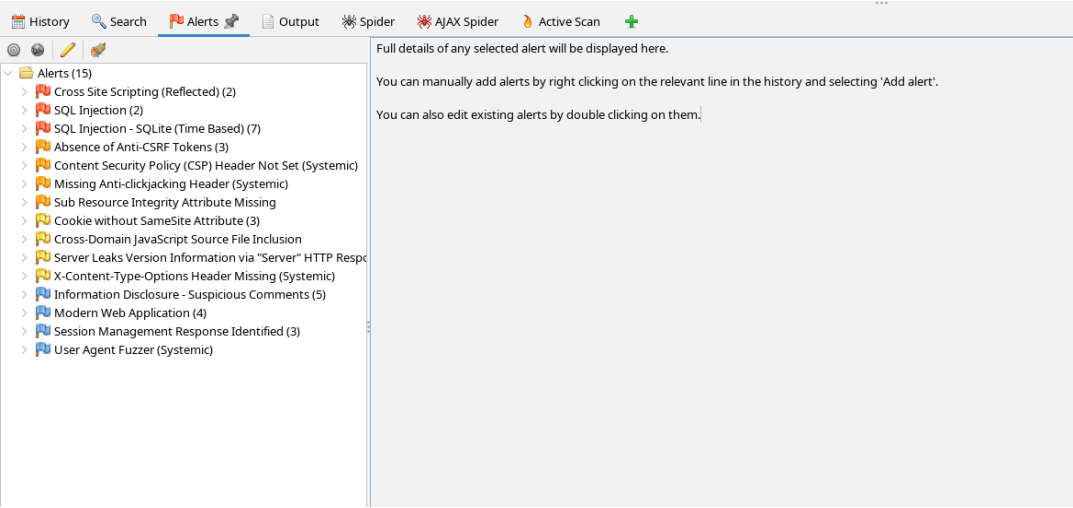


Figure 2 — ZAP Alerts panel (15 alert categories identified)

Note on Scope

XSS and SQL Injection categories were flagged by the tool's automated testing. These are recorded as tool findings only — no manual exploitation was performed, in line with the assessment's passive scope.

Browser DevTools — Response Headers

Chrome DevTools was used to inspect the raw HTTP response returned by the server, confirming the header gaps flagged by ZAP.

Present

- ✓ Content-Type
- ✓ Date
- ✓ Server
- ✓ Transfer-Encoding

Missing

- ✗ Content-Security-Policy
- ✗ X-Frame-Options
- ✗ Strict-Transport-Security
- ✗ X-Content-Type-Options

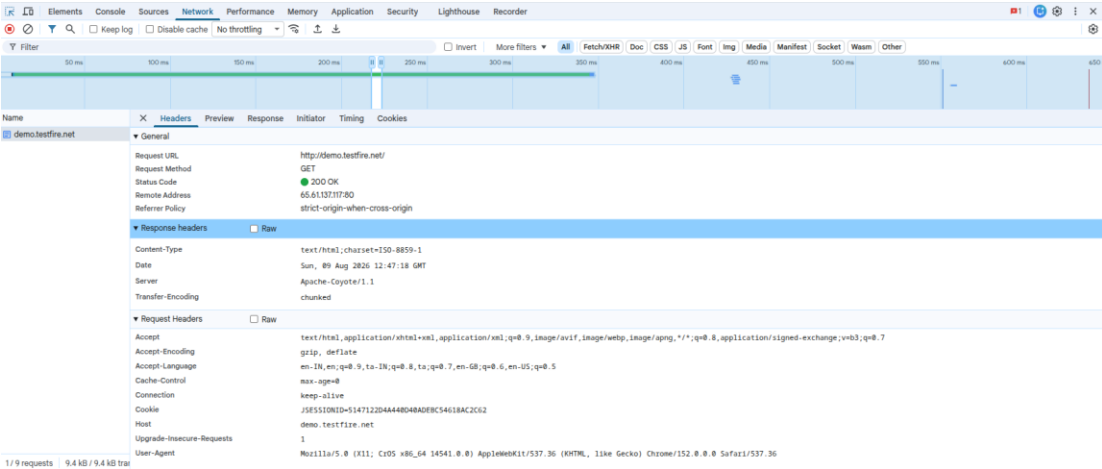


Figure 3 — Response headers for demo.testfire.net (DevTools Network tab)

Risk Level: Medium

Bonus finding: Server header reveals Apache-Coyote/1.1, exposing exact software version.

Recommendation: Configure the server to send standard security headers.

Browser DevTools — Cookie Analysis

The session cookie (JSESSIONID) was inspected for security attributes that protect it from theft or misuse.



HttpOnly

Set



Secure

Not Set



SameSite

Not Set

Risk Level: Medium

Recommendation: Set the Secure and SameSite attributes on all session cookies.

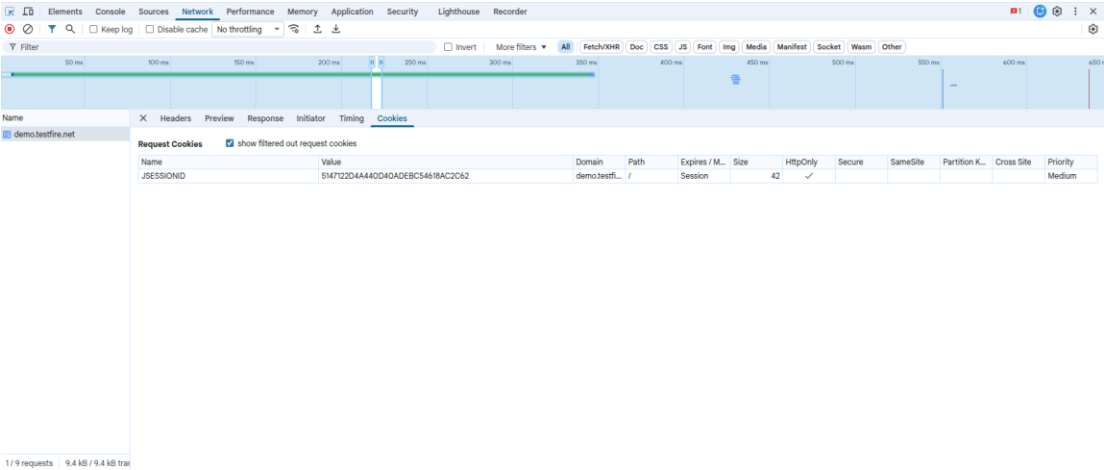


Figure 4 — JSESSIONID cookie attributes (DevTools Cookies tab)

Findings & Risk Assessment Summary

Finding	Risk Level	Status
Multiple ports exposed (incl. 8080)	Low–Medium	Completed
Missing security headers (CSP, X-Frame-Options, etc.)	Medium	Completed
Absence of Anti-CSRF tokens	Medium	Completed
Session cookie missing Secure / SameSite flags	Medium	Completed
Server version disclosure	Low	Completed
Informational comments in page source	Low / Info	Completed

Overall Risk: Medium — Assessment completed using passive and automated scanning; no manual exploitation performed.

Recommendations

1

Implement standard HTTP security headers (CSP, X-Frame-Options, X-Content-Type-Options, HSTS)

2

Set Secure and SameSite attributes on all session cookies

3

Implement anti-CSRF tokens on all forms

4

Suppress server version information in HTTP responses

5

Restrict or close unnecessary open ports (e.g. 8080)

6

Perform regular vulnerability assessments and apply timely patches

Conclusion

The vulnerability assessment of demo.testfire.net was conducted using passive and automated security testing techniques with Nmap, OWASP ZAP, and Chrome DevTools.

The assessment identified several configuration weaknesses — including missing security headers, cookie misconfigurations, and exposed network services — which, while not critical, represent meaningful opportunities to strengthen the application's security posture.

Implementing the recommendations in this report would meaningfully reduce the application's overall risk.

References

OWASP ZAP Documentation — zaproxy.org | Nmap Reference Guide — nmap.org | OWASP Web Security Testing Guide — owasp.org